

ShieldAI

The Virtual CISO Platform

Affordable today. A managed-security platform at scale.

BUSINESS PLAN

Confidential · 2026

Prepared by Xandu Limited, LLC

Contents

1. Executive Summary
 - Key Highlights
2. The Problem & Market Opportunity
 - 2.1 The SMB Security Gap
 - 2.2 Market Size
 - 2.3 Market Sizing (Bottom-Up)
 - 2.4 Why Now
3. Product & Platform
 - 3.1 What the Customer Gets
 - 3.2 The Scoring Engine — Our Core IP
 - 3.3 The Role of AI
4. Strategy: Wedge to Platform
 - 4.1 The Wedge — Self-Serve Product
 - 4.2 The Expansion — Managed vCISO Programs
 - 4.3 The Platform — The Analyst Console
5. Business Model
 - 5.1 Revenue Streams
 - 5.2 Pricing Tiers
 - 5.3 Unit Economics — The Scalability Engine
6. Financial Projections
7. Competitive Landscape & Defensibility
 - 7.1 The Landscape
 - 7.2 Why We Win
8. Product Roadmap
9. Team & Execution
10. The Ask & Use of Funds
11. Risk Analysis & Mitigation
12. Summary

1. Executive Summary

“A full-time CISO costs \$200,000–\$400,000 a year. Nearly half of small businesses have no security budget at all — yet their insurers, customers, and regulators now require a real security program. ShieldAI closes that gap.”

ShieldAI is a virtual Chief Information Security Officer (vCISO) platform for small and mid-sized businesses (SMBs). It delivers a complete, continuously-managed security program — risk scoring, written policies, a prioritized roadmap, compliance mapping, awareness training, and executive reporting — at a price a small business can actually afford.

Our strategy is a deliberate wedge-to-platform progression. We begin with a free assessment and an affordable, largely self-serve tier ladder that delivers immediate value and proves the model. As clients grow, we layer human expertise on top: cybersecurity engineers who use ShieldAI to run full, managed CISO programs for a portfolio of clients — with the software (and an AI co-pilot) doing the heavy lifting so a small team can protect a large book of businesses. This is how we move from a low-cost tool to a high-value managed-security platform without a linear increase in headcount.

ShieldAI is powered by frontier AI for analysis and content generation, but our defensibility does not rest on the AI itself. It rests on four things: a proprietary, deterministic security-scoring engine built on the NIST Cybersecurity Framework that produces explainable, auditor- and insurer-trustworthy results; a human-in-the-loop model in which qualified engineers review and approve work before it reaches the client; the proprietary assessment data and client relationships that compound over time; and direct-to-SMB distribution at a price point the market's best-funded players have left structurally uncontested (see Section 7 and the companion Competitive Analysis).

Key Highlights

Metric	Detail
Target market	U.S. SMBs with employees, prioritizing regulated and insured segments
Core category	Virtual CISO (vCISO) — ~\$2B+ today, growing 12–15%+ annually
Demand driver	Cyber-insurance, customer security requirements, and regulation forcing SMBs to act
Model	Five-tier ladder — Free → Starter → Growth → Guided → Managed vCISO — land-and-expand into engineer-run managed programs
Differentiation	Deterministic NIST scoring engine + human-in-the-loop + direct-to-SMB reach nobody else in the category has
Stage	Working product live in production — assessment, scoring, program & policy generation, 12 compliance frameworks, billing infrastructure, monitoring agent
Next milestone	Convert the analyst console from mockup to live; hire first security engineers

This plan reflects ShieldAI's current direction: the self-serve product is built and functioning in production; this raise funds the build-out of the managed-services platform layer that turns it into a scalable business.

2. The Problem & Market Opportunity

2.1 The SMB Security Gap

Small businesses face the same threat landscape as enterprises — ransomware, phishing, business email compromise, supply-chain attacks — but lack the budget, expertise, or time to respond. They are caught in a structural bind: too big

to ignore security, too small to afford a dedicated leader. A full-time CISO costs \$200,000–\$400,000 or more per year, while the foundational tools and expertise cost roughly the same whether a business has 10 employees or 100 — so the per-employee burden falls hardest on the smallest firms.

The data shows how exposed this segment is:

- 47% of businesses with fewer than 50 employees have no cybersecurity budget at all (StrongDM / CrowdStrike, 2025).
- 51% have no security measures in place; one-third rely on free, consumer-grade tools.
- Only 34% have a formal incident response plan (Guardz, 2025).
- Only ~13% conduct proactive security audits, and only ~1 in 5 performs annual penetration testing.
- Small businesses represent roughly 43% of all cyberattacks, and SMB incident rates rose ~47% year over year.

The cost of inaction is severe and quantifiable: IBM data shows a tested incident-response plan reduces breach cost by approximately \$232,000, and prevention investment returns consistently exceed 7x. A foundational program costing \$5,000–\$15,000 a year would save hundreds of thousands in the event of a breach — yet the businesses that spend nothing are the ones that pay the most.

2.2 Market Size

ShieldAI sits in the virtual CISO category, inside the broader SMB cybersecurity market. (See the companion Market Analysis for the full sourced breakdown.)

Market	Size / Estimate	Source
U.S. small businesses	36.2M total; ~5.8M with employees	SBA Office of Advocacy, 2025
Global SMB cybersecurity spend	~\$109B by 2026, ~10% CAGR	Analysys Mason
Virtual CISO market (global)	~\$2B+ in 2025, 12–15%+ CAGR	Composite (multiple research firms)
U.S. cyber-insurance market	~\$3.9B (2025), ~22% CAGR	Market Research Future

vCISO market estimates vary by research firm — from roughly \$1.06B to \$2.89B for 2024–25, with forecasts ranging from \$1.5B to \$12B by the early 2030s — because firms scope the category differently. Every credible source agrees on the direction: double-digit annual growth driven by escalating threats, a 3.4-million-person global cybersecurity talent shortage, and tightening compliance.

2.3 Market Sizing (Bottom-Up)

- TAM: The global vCISO category, ~\$2B+ and growing 12–15%+ per year — the market we directly serve.
- SAM: ~5.8M U.S. employer businesses, narrowed to regulated/insured/supply-chain segments (a conservative 10–20% → roughly 600K–1.2M businesses). At a blended program value in the low thousands per year, this is a multi-billion-dollar serviceable market.
- SOM: A modest, credible early capture — e.g., 1% of a 600K-business SAM at a few thousand dollars per year per client — represents a business on the order of \$20M+ in annual recurring revenue, reached over a 3–5 year horizon via the self-serve-to-managed motion.

Final ARPU, pricing tiers, and segment definitions are informed by the pricing and unit economics in Sections 5–6 below.

2.4 Why Now

The decisive shift is that demand is no longer driven by whether small businesses care about security, it is being forced on them by three external pressures converging at once:

- **Cyber-insurance as gatekeeper:** Insurers now require proof of specific controls (MFA, incident response, etc.) before issuing or renewing policies. 63% of SMBs saw premiums rise 200%+ in 2025, and businesses under \$25M in revenue filed 64% of all cyber-insurance claims — so insurers are tightening precisely on our target segment.
- **Customer-driven requirements:** Larger customers increasingly push security questionnaires and insurance requirements down to their small vendors. Without a demonstrable program, small businesses lose contracts.
- **Expanding regulation:** HIPAA, CMMC (defense supply chain), the FTC Safeguards Rule, and state privacy laws now carry real penalties — reaching deep into the small-business tier.

On the supply side, AI has only recently become capable enough to deliver expert-level security analysis and documentation at a cost that makes serving the small-business segment economically viable. The need and the means have arrived at the same moment.

3. Product & Platform

3.1 What the Customer Gets

From a short, structured assessment, ShieldAI produces a complete security program through a unified dashboard:

- **Security assessment:** a conversational intake plus a structured, NIST-mapped checklist that captures the business's context and current posture.
- **Deterministic risk score:** an explainable security-posture score (see 3.2) with a per-function breakdown.
- **Prioritized roadmap:** ranked actions with effort, impact, cost, and ownership — including immediate quick wins.
- **Professional policy library:** complete, formatted, ready-to-use policy documents (Acceptable Use, Incident Response, Access Control, Data Classification, and more), downloadable as Word files and tailored to the business.
- **Compliance mapping:** gap analysis against the frameworks relevant to the business — 12 frameworks supported today, including HIPAA, PCI DSS v4.0, SOC 2, CMMC 2.0, ISO 27001, and NIST 800-171 — with remediation guidance.
- **Incident response workflows,** a recommended tool stack, a standalone awareness-training product, and board-ready executive reporting.

3.2 The Scoring Engine — Our Core IP

ShieldAI's differentiator is a deterministic risk-scoring engine built on the NIST Cybersecurity Framework. Unlike an AI that “guesses” a number, the engine computes a posture score across the five NIST functions — Identify, Protect, Detect, Respond, and Recover — each weighted and scored from the structured assessment. The same inputs always produce the same score, and every point traces to a specific control.

This matters commercially: an insurer, auditor, or enterprise customer can trust an explainable, repeatable score in a way they would never trust an opaque AI output. The scoring methodology is proprietary and improves as our assessment dataset grows. A CI-enforced integrity guard fails the build if any framework's control mapping lacks a documented scoring method — 96% of supported frameworks are fully assessed today, with zero unbacked claims shipped to clients.

3.3 The Role of AI

Frontier AI powers the analytical and generative work — interpreting the assessment, drafting tailored policies, generating training and reporting, and (in the platform layer) assisting our engineers. The architecture is model-flexible and routes work to the model best suited to it: Anthropic's Claude for reasoning and writing, Google Gemini for threat intelligence and search grounding, and OpenAI's GPT-4o for tool recommendations and training content. Every AI-generated artifact in the product carries a badge naming which model produced it, recorded at generation time — not hardcoded — so the provenance of every deliverable is auditable. Crucially, the AI accelerates expert work rather than replacing expert judgment — which is central to both our quality bar and our liability posture.

4. Strategy: Wedge to Platform

4.1 The Wedge — Self-Serve Product

The entry point is a free assessment, followed by an affordable, largely self-serve tier ladder. A business completes an assessment, receives a real posture score and a complete program, and can generate and download professional policies — immediate, tangible value at a fraction of the cost of a consultant. This wedge gets businesses in the door at zero-to-low cost, proves the model, and builds the assessment dataset that strengthens our scoring engine.

4.2 The Expansion — Managed vCISO Programs

As clients grow or face greater compliance demands, they graduate to managed plans in which a ShieldAI cybersecurity engineer runs their security program on an ongoing basis. This is higher-value, higher-retention recurring revenue, and it is where the human-in-the-loop model delivers both quality and trust.

4.3 The Platform — The Analyst Console

The engine of scale is an internal analyst console: a command center where each engineer manages a portfolio of client businesses, strictly scoped to their assigned clients only. From a single interface an engineer monitors every client's posture and trend over time, sees live alerts from read-only monitoring agents deployed in client networks, communicates directly with clients, and reviews and approves the AI's work before it ships. An integrated AI co-pilot — “ShieldAI Mastermind” — is strictly advisory: it triages threats, diagnoses issues, and surfaces compliance gaps, but has no inbound command channel and cannot act on a client's environment. One engineer can do what previously required a whole team, without ever giving the AI the ability to act unilaterally.

A working mockup of this console exists today; converting it into a live, agent-fed product is a primary objective of this raise. This is the layer that transforms cybersecurity consulting from a headcount-bound business into a scalable platform.

The AI does the first 80%. The engineer adds the high-value 20% — judgment, accountability, and the client relationship. That blend is our margin and our quality bar.

5. Business Model

5.1 Revenue Streams

- Self-serve subscriptions (Starter, Growth) — low-cost, high-volume entry tiers; the wedge.
- Guided subscriptions — self-serve plus periodic engineer touch, the bridge to fully managed.
- Managed vCISO plans — engineer-run programs; the primary recurring-revenue engine.

- Training delivery add-on — \$40/month standalone add-on for Starter clients; bundled free at Growth tier and above.
- Channel / partnerships — referrals from cyber-insurers, MSPs, and professional-services firms whose clients are required to demonstrate controls (a natural low-CAC path).
- Add-ons — compliance-readiness packages, cyber-insurance documentation, and specialized policy work.

5.2 Pricing Tiers

Pricing is set to undercut traditional human-only vCISO retainers — which typically run \$2,500–\$11,600/month for SMB clients — while remaining more complete than automated-only tools. Because AI performs the heavy lifting at a measured cost of \$0.28 per client per month, ShieldAI can offer a free entry point and price every paid tier for real SMB budgets while still holding healthy margins as the business scales (see 5.3).

Tier	Price / mo	What it includes	Target customer
Free	\$0	Security assessment and posture score only	Top-of-funnel; zero-friction entry
Starter	\$159	Full program generation, policy library, and endpoint monitoring — no engineer time	Micro-businesses; the wedge
Growth	\$349	Expanded policy and endpoint coverage, full training program access, downloads/exports	Growing SMBs formalizing their program
Guided	\$699	Growth, plus periodic engineer review, compliance tracking, and check-ins	SMBs with active compliance needs
Managed vCISO	\$1,950	A ShieldAI engineer runs the security program end-to-end — still below human-only competitors	Regulated / insured / supply-chain SMBs

A \$40/month training delivery add-on — tokenized learner links, quarterly scheduling, and fleet-wide reporting — is available on Starter and bundled free at Growth tier and above.

The ladder is designed for land-and-expand: a business can start at \$0 and grow into managed plans as trust builds and compliance demands increase. The Managed tier deliberately sits at or below the bottom of the traditional retainer range — “a fractional CISO at a fraction of the cost.”

5.3 Unit Economics — The Scalability Engine

The defining economics are at the Managed tier, where the analyst console and AI co-pilot let a single cybersecurity engineer manage roughly 25 clients with a high-touch service level.

Metric	Value
Managed price	\$1,950 / month
Clients per engineer	~25 (enabled by the AI-amplified console)
Revenue per engineer	~\$585,000 / year
Fully loaded engineer cost	~\$140,000 / year
AI + infrastructure cost	\$0.28 / client / month (measured production figure)

Metric	Value
Gross contribution per engineer	~\$445,000 / year (~76% margin)

This corrects an earlier planning estimate that assumed \$15/client/month in AI cost — roughly 50x the measured figure. The corrected number strengthens, rather than changes, the investment thesis: at the per-engineer level, AI cost is now immaterial (~\$84/year against \$585,000 in revenue), and the gross-contribution margin is a function almost entirely of engineer utilization, not AI spend.

Because the company carries real payroll (product engineers, leadership, sales & marketing, and G&A) ahead of revenue in the early months, the blended, company-wide margin is lower than the per-engineer figure above and expands over time as the client book grows faster than headcount:

Blended Margin	Year 1	Year 2	Year 3
Gross Margin	~12%	~58%	~74%
EBITDA Margin	~(147)%	~2%	~44%

This is the crux of the investment thesis: revenue scales with the client book while engineer headcount grows far more slowly, because the software does the heavy lifting. Self-serve tiers add high-margin, low-touch revenue on top, and margins expand steadily as the mix shifts and fixed costs are absorbed over a larger base. See the companion 3-Year Financial Model for the full monthly build.

6. Financial Projections

The following is an illustrative three-year ramp built from a full monthly model (see the companion 3-Year Financial Model workbook), reflecting the five-tier pricing ladder, measured AI costs, and a founder-planned headcount build. It assumes a deliberate mix shift toward higher tiers as the platform matures, with delivery-engineer headcount scaled to the Guided and Managed book.

	Year 1	Year 2	Year 3
Free clients (top of funnel)	500	1,800	4,500
Starter clients	90	300	750
Growth clients	40	150	400
Guided clients	25	100	260
Managed clients	15	60	200
Total paying clients	170	610	1,610
Team headcount (all roles)	5	13	23
Revenue (full year)	~\$0.3M	~\$2.0M	~\$6.5M
ARR (annualized run-rate, year-end)	~\$0.9M	~\$3.5M	~\$10.1M
Gross Margin	~12%	~58%	~74%
EBITDA Margin	~(147)%	~2%	~44%

Full-year revenue and year-end ARR run-rate are shown separately because the client base ramps throughout each year — year-end ARR annualizes the final month, while full-year revenue reflects the actual ramp. These figures illustrate the model's shape and the operating leverage of the engineer-plus-AI structure; they are planning estimates, not commitments, and will be refined with real acquisition and retention data. The key dynamic to note is that Year 3 ARR is roughly 11x Year 1 ARR while headcount grows less than 5x — the signature of a platform rather than a consultancy.

Under this plan, the \$900,000 seed raise (Section 10) is never fully exhausted — modeled cash reaches its low point of roughly \$130,000 around Month 18 before the business turns cash-flow positive, consistent with Series A readiness in the Month 22–24 window. See the companion 3-Year Financial Model for the full monthly cash-flow build.

7. Competitive Landscape & Defensibility

7.1 The Landscape

The five most-visible names in vCISO and GRC software split into two categories, neither of which sells directly to a small business at a small-business price. Full profiles, pricing, and positioning appear in the companion Competitive Analysis; the summary:

Category	Examples	Limitation	ShieldAI Edge
Traditional vCISO / consultancies	Fractional CISO, FRSecure, Kroll	Human-only; expensive; priced for mid-market+	AI does the heavy lifting — we serve the small end profitably
AI-native vCISO platform (via MSPs)	Cynomi (\$37M Series B, Apr. 2025; 3x ARR growth in 2024)	Sells only through MSPs/MSSPs — the small business never sees or chooses it	We sell directly to the business; every deliverable is engineer-reviewed
Compliance / GRC automation (VC-funded tech buyers)	Vanta, Drata, Secureframe (\$7.5K–\$100K+/year each)	Priced and built for cloud-native startups chasing SOC 2/ISO 27001, not Main Street SMBs	Full CISO program — policies, roadmap, training — not just evidence collection, at 1/5 to 1/50 the price
Mid-market multi-framework GRC	Scrut Automation (\$15K–\$40K/year, 50–500 employee sweet spot)	Requires GRC expertise to configure; positioned above true small businesses	Built for a business with no dedicated security or compliance staff

7.2 Why We Win

- Proprietary scoring methodology: explainable, repeatable, and trusted by insurers and auditors — not an opaque AI guess.
- Human-in-the-loop: expert review makes output trustworthy enough to sell and materially limits liability — a layer none of the four self-serve compliance platforms above offer at any price.
- Compounding data and relationships: every assessment and managed client makes the system smarter and stickier.
- Direct-to-SMB reach at an SMB price: the lane every well-funded competitor above has left structurally open — Cynomi sells through MSPs, and Vanta/Drata/Secureframe/Scrut sell to venture-funded technology companies at 4–50x ShieldAI's price.

- The AI is the commodity; the system around it — methodology, workflow, engineers, data, and direct distribution — is the moat. A well-funded competitor cannot trivially replicate the whole system.

8. Product Roadmap

Phase 1 — Live Today: The Self-Serve Product

- Conversational intake + structured NIST checklist; deterministic posture scoring.
- AI-generated security program: roadmap, policies, compliance mapping, workflows, training, executive report.
- Professional policy generation with Word export; user accounts; admin tooling; five-tier billing infrastructure; read-only cross-platform monitoring agent.

Phase 2 — This Raise: The Managed Platform

- Convert the analyst console from mockup to live (portfolio view, per-client command centers).
- Hire and onboard the first cybersecurity engineers to run managed programs.
- Live “Mastermind” AI co-pilot for engineers; review-and-approval workflow in production.
- Client messaging, weekly automated program reporting, and compliance progress tracking.

Phase 3 — Scale: Telemetry & Automation

- Deploy network agents in client environments for live posture and threat telemetry — permanently read-only, with no inbound command channel.
- Continuous monitoring, automated alerting, and agent-fed recommendations, always routed through human review.
- Channel partnerships (insurers, MSPs) for low-CAC distribution; expand client base and verticals.

9. Team & Execution

ShieldAI is being built by Xandu Ltd. The product is already developed and functioning, demonstrating execution capability and meaningfully de-risking the technical plan. The immediate organizational priority funded by this raise is hiring the first cybersecurity engineers — the people who run managed client programs through the analyst console — alongside continued product engineering.

Because the platform model amplifies each engineer with AI, the team can stay lean relative to the size of the client book it supports. Security leadership and qualified engineering talent are the key early hires, given that the managed offering depends on credible, accountable human expertise.

[Insert founder/team bios and relevant security, SaaS, and go-to-market experience here.]

10. The Ask & Use of Funds

ShieldAI is raising \$900,000 in seed funding to fund the transition from a working self-serve product to a managed-security platform over the next 18–24 months.

Use of Funds	Amount	%
Engineering (analyst console to live + network agents)	\$320,000	36%

Use of Funds	Amount	%
First security engineers (2–3 hires)	\$280,000	31%
Go-to-market & channel partnerships	\$180,000	20%
Operations, SOC 2, legal & compliance	\$90,000	10%
Working capital reserve	\$30,000	3%

This capital takes ShieldAI to Series A readiness in the Month 22–24 window: a managed-services platform in production, the first cohort of engineers running client programs, an ARR run-rate crossing \$3M, and proven managed-tier retention and unit economics. Under the accompanying financial model, the raise is never fully exhausted — modeled cash bottoms out around \$130,000 near Month 18 before the business turns cash-flow positive.

A full-time CISO costs a quarter-million dollars a year. ShieldAI delivers that protection for the price of a subscription — and the platform lets a handful of our engineers protect thousands of businesses.

11. Risk Analysis & Mitigation

Risk	Mitigation
AI output accuracy / hallucination	Deterministic scoring engine for the trust-critical number; human engineer reviews and approves all client-facing deliverables before release.
Liability if a managed client is breached	Human-in-the-loop accountability; clear scope and terms on the self-serve tiers; appropriate professional and cyber insurance; SOC 2 posture.
Well-funded competitor (e.g., Cynomi's \$37M Series B, or a Vanta/Drata SMB-tier launch)	Differentiate on proprietary scoring methodology, the managed services + platform model, direct-to-SMB distribution, and accumulated data and relationships rather than the AI alone — see companion Competitive Analysis for the full landscape and watch items.
AI API cost or terms change	Model-flexible architecture; proprietary logic and scoring sit above any single provider; substitute models as needed.
Customer churn ("security feels done")	Managed plans and continuous monitoring make the program perpetually valuable; compliance cycles and reporting anchor retention.
Scaling human expertise	The analyst console + AI co-pilot are designed precisely so each engineer manages many clients without linear headcount growth.

12. Summary

ShieldAI addresses a large, underserved, and — critically — a forced-demand market: tens of millions of small businesses that now must demonstrate a real security program but cannot afford to staff one. We enter with an affordable, working self-serve product and expand into high-value managed programs delivered by cybersecurity engineers who are amplified by our software and AI co-pilot.

Our defensibility is a system, not a feature: a proprietary, explainable NIST scoring engine; a human-in-the-loop model that makes our output trustworthy enough to sell; the data and relationships that compound with every client; and direct-to-SMB distribution that the five best-funded names in the category — Cynomi, Vanta, Drata, Secureframe, and Scrut Automation — have each left structurally uncontested. The product is already built. This fundraise funds the platform layer that turns it into a scalable business.

ShieldAI · Confidential · 2026